

보안성검증자료 — 에어갭반입 Docker 이미지 (SBOM + 취약점스캔)

- 작성일: 2026-08-04
- 작성자: jhkang (illunex), Claude Code 지원
- 대상: docker-compose.deploy.yml 기반에어갭반입번들에포함된전체이미지 8 종
- 도구: Trivy v0.73.0 (Aqua Security, OSS) — SBOM 생성 + OS/언어패키지취약점스캔을단일도구로수행
- 취약점 DB: mirror.gcr.io/aquasec/trivy-db:2, DB version 2, UpdatedAt 2026-08-04 01:17:42 UTC (스캔시점최신)
- SBOM 형식: CycloneDX 1.x (JSON)
- 원본자료경로: 본문서와같은폴더의 sbom/*.cdx.json(SBOM), scans/*.json(Trivy 원본스캔결과, 상세 CVE 전체목록포함), scan_summary.json(심각도별집계 + CRITICAL/HIGH 요약율이문서작성을위해추출한중간산출물)

본문서는 “자율양식” 제출요건에맞춘요약보고서다. 제출처가특정 SBOM 표준 (SPDX 등) 이나특정스캐너지정을요구하면그에맞춰재생성가능 — Trivy 는 --format spdx-json 도지원한다.

1. 검증대상이미지목록

#	이미지: 태그	Image ID(sha256, 앞 12 자)	크기	용도 / 반입번들
1	nice/migrate:dev	cf9bb6ab0296	376MB	company_edge rate/공유유통인 CLI + IPython 셸. nice_migrate.image.tar.gz
2	nice/migrate2:dev	cf9bb6ab0296	376MB	위와 완전동일이미지 (같은 Image ID) — 별도이름으로재반입한사본. nice_migrate2.image.tar.gz
3	nice/rag-server:dev	74513ae61d26	537MB	HS 코드검색 RAG API. nice_ai_app.tar.gz
4	nice/ingestion:dev	ea725b25e1d4	539MB	데이터적재/임베딩배치 잡. nice_ai_app.tar.gz
5	nice/shock-server:dev	b4085be26c6f	263MB	쇼크전파계산 API(DB-free). nice_ai_app.tar.gz
6	nice/postgres:pg16	17ee2618c5f6	438MB	자체호스팅 Post-greSQL(pgvector/pg_trgm/btree_gin). 별도빌드·반입
7	ollama/ollama:latest	dd1a385ce665	4.85GB	LLM 서빙 (qwen3:14b 등). nice_ai_llm.tar.gz
8	ghcr.io/huggingface/text-embeddings-inference:cpu-1.6	011f81cf9cf6	666MB	임베딩서빙 (bge-m3). nice_ai_embed.tar.gz

#1·#2 는같은빌드 (deploy/migrate/Dockerfile, 동일커밋) 라스캔결과가완전히동일하다. 아래요약·상세는중복게재를피하기위해 nice_migrate 하나로대표한다 (원본파일은둘다보존).

2. 심각도별요약

이미지	Base OS	CRITICAL	HIGH	MEDIUM	LOW
nice/migrate (=migrate2)	Debian 13.6 (trixie)	4	61	111	113
nice/rag-server	Debian 13.6 (trixie)	4	27	81	101
nice/ingestion	Debian 13.6 (trixie)	4	27	81	101
nice/shock-server	Debian 13.5 (trixie)	4	27	82	101
nice/postgres:pg16	Debian 12.13 (bookworm)	22	59	164	179
ollama/ollama:latest	(멀티스테이지, distroless 계열)	0	33	78	30
text-embeddings-inference:cpu-1.6	Debian 12.10 (bookworm)	12	83	161	218

- nice/migrate*rag-server-ingestion-shock-server 는모두같은 python:3.11-slim(Debian 13 trixie) 베이스라 CRITICAL 4 건이공통으로나타난다 (§3-A).
- ollama/ollama:latest 는이번스캔에서 CRITICAL 0 건 — 가장양호.
- nice/postgres:pg16(Debian 12 bookworm) 과 text-embeddings-inference:cpu-1.6 은상대적으로오래된 bookworm 베이스라 CRITICAL/HIGH 건수가더많다 (§3-B, §3-C).

3. CRITICAL 상세및조치가가능여부

3-A, nice/migrate / rag-server / ingestion / shock-server 공통 (Debian 13 trixie 베이스)

CVE	패키지	설치버전	수정버전	비고
CVE-2026-13221	perl-base	5.40.1-6	미정 (업스트림패치대기)	
CVE-2026-42496	perl-base	5.40.1-6	미정	
CVE-2026-57433	perl-base	5.40.1-6	미정	
CVE-2026-8376	perl-base	5.40.1-6	미정	

평가: 4 건전부 perl-base(Debian 베이스이미지에기본포함되는패키지) 한곳에몰려있고, 현재 (스캔시점) 업스트림수정버전이아직없다. nice_migrate/rag-server/ingestion/shock-server 컨테이너는애플리케이션코드가 **perl** 을호출하지않는다 (Python 전용 CLI/API) — 즉이패키지가런타임공격표면에서제로노출되지는않으나, 이미지에존재자체는사실이므로투명하게명시한다. 업스트림패치가나오면베이스이미지재빌드 (docker build) 만으로자동해소된다 (코드변경불필요).

3-B, nice/postgres:pg16 (22 건, Debian 12 bookworm)

주요항목 (전체목록은 scans/nice_postgres_pg16.json 참고):

CVE	패키지	설치버전	수정버전	조치가가능?
CVE-2026-33845, CVE-2026-42010	libgnutls30	3.7.9-2+deb12u6	3.7.9-2+deb12u7	[해소가능] apt 업그레이드로해소가능
CVE-2025-68121	stdlib(Go, gosu 바이너리내장)	v1.24.6	1.24.13/1.25.7/1.26.0-rc.3	[해소가능] gosu 재빌드 (최신 Go 로컴파일) 로해소가능
CVE-2026-13221 등 4 건	libperl5.36/perl/perl-base/perl-modules	5.36.0-7+deb12u3	미정	[주의] 업스트림대기 (§3-A 와동일성격)
CVE-2025-7458	libsqlite3-0	3.40.1-2+deb12u2	미정	[주의] 업스트림대기
CVE-2026-6653	libxml2	2.9.14+dfsg-1.3~deb12u5	미정	[주의] 업스트림대기
CVE-2023-45853	zlib1g	1:1.2.13.dfsg-1	미정 (Debian 자체미출시)	[주의] 업스트림대기

권고: deploy/postgres/Dockerfile 재빌드시 apt-get upgrade(또는베이스이미지재당김) 로 libgnutls30 최소 1 건은즉시해소가능. gosu 는최신릴리스로교체권고.

3-C. text-embeddings-inference:cpu-1.6 (12 건, Debian 12 bookworm)

CVE	패키지	설치버전	수정버전	조치가가능?
CVE-2026-33845, CVE-2026-42010	libgnutls30	3.7.9-2+deb12u4	3.7.9-2+deb12u7	[해소가능]
CVE-2026-31789	libssl3/libssl-dev/openssl	3.0.15-1~deb12u1	3.0.19-1~deb12u2	[해소가능]
CVE-2024-56171	libxml2	2.9.14+dfsg-1.3~deb12u1	2.9.14+dfsg-1.3~deb12u2	[해소가능]
나머지 5 건 (perl-base 4·zlib1g 1·libxml2 1)	—	—	미정	[주의] 업스트림대기

평가: HuggingFace 공식이미지 (ghcr.io/huggingface/...) 를그대로사용중 — 자체빌드가아니라 Dockerfile 수정으로해소불가. 최신 cpu-1.6.x 패치태그로재반입하면 openssl/libgnutls/libxml2 3 건은해소될가능성이높다 (업스트림이미지가베이스를재빌드했다면).

3-D. ollama/ollama:latest

CRITICAL 0 건. HIGH 33 건은 scans/ollama_ollama_latest.json 참고 (주로 Go 모듈의존성).

4. 제한사항 (Limitations)

- **시점스캔 (point-in-time)**: 2026-08-04 기준 Trivy DB(2026-08-04 01:17 UTC 업데이트) 로스캔한결과다. 신규 CVE 는매일추가되므로, 실제반입직전재스캔을권고한다 (§5 재현방법참고). ollama/ollama:latest 처럼 latest 태그를쓰는이미지는반입시점에실제로받은이미지의 digest(docker inspect --format='{{.Id}}') 를별도기록해이보고서의 Image ID(§1) 와일치하는지확인할것 — 태그는갈아도원격저장소의 latest 가갱신되면다른이미지일수있다.
- **정적스캔한정**: OS 패키지·언어패키지 (Python 등) 메타데이터기반정적취약점매칭이다. 런타임동작스캔 (DAST), 시크릿스캔 (자격증명하드코딩등), 코드자체 SAST 는범위밖 — 필요시 trivy fs(코드스캔)·trivy image --scanners secret 별도실행가능.
- **CRITICAL/HIGH 라도실제공격표면과무관할수있음**: §3-A 의 perl-base 처럼이미지에설치는됐으나애플리케이션이호출하지않는패키지는심각도라벨과별개로실질위험이낮다 — 본보고서는이런맥락을최대한병기했으나, 최종위험수용여부는제출처보안심의기준에따른다.
- **nice/migrate vs nice/migrate2**: 완전히동일한이미지 (§1 주석). 두이름으로반입해도실제자산은하나이므로이중계상하지않도록유의.

5. 재현방법 (다른사람이동일결과를재현하려면)

Trivy 설치 (버전 고정 권장)

```
curl -sfl https://raw.githubusercontent.com/aquasecurity/trivy/main/contrib/install.sh \
| sh -s -- -b /usr/local/bin v0.73.0
```

이미지별 SBOM(CycloneDX) + 취약점 스캔 (JSON) 생성 —예: nice/migrate:dev

```
trivy image --format cyclonedx --output nice_migrate.cdx.json nice/migrate:dev
trivy image --format json --output nice_migrate.json nice/migrate:dev
```

사람이 보기 좋은 표 형태로 즉석 확인

```
trivy image --severity CRITICAL,HIGH nice/migrate:dev
```

6. 첨부파일목록

docs/security/

└─ SECURITY_VERIFICATION_20260804.md (본 문서)

└─ SECURITY_VERIFICATION_20260804.pdf (PDF 버전, 제출용)

- └─ scan_summary.json (심각도 집계 + CRITICAL/HIGH 상세 — 이 문서의 원천 데이터)
- └─ sbom/
 - └─ nice_migrate.cdx.json (= nice_migrate2.cdx.json, 동일 이미지)
 - └─ nice_migrate2.cdx.json
 - └─ nice_rag-server.cdx.json
 - └─ nice_ingestion.cdx.json
 - └─ nice_shock-server.cdx.json
 - └─ nice_postgres_pg16.cdx.json
 - └─ ollama_ollama_latest.cdx.json
 - └─ tei_cpu-1.6.cdx.json
- └─ scans/ (Trivy 원본 결과 — CVE 전체 목록, CVSS, 참고링크 포함)
 - └─ nice_migrate.json (= nice_migrate2.json)
 - └─ nice_migrate2.json
 - └─ nice_rag-server.json
 - └─ nice_ingestion.json
 - └─ nice_shock-server.json
 - └─ nice_postgres_pg16.json
 - └─ ollama_ollama_latest.json
 - └─ tei_cpu-1.6.json